

IR. H. SCHOONE
CONSUL RISK MANAGEMENT BV
THE NETHERLANDS
SECURITY EVALUATION CRITERIA - POSITION PAPER C4

SECURITY EVALUATION CRITERIA

POSITION PAPER

This paper is a position paper on security evaluation criteria. The paper is prepared by Jaap den Engelsman, Martin de Graaf, Paul Overbeek, Hans Schoone en Leon Strous, members of working group *SB.W06 Security Evaluation Criteria* of the Special Interest Group on Information Security (SIGIS) of the Dutch Computer Society (NGI). During the process of preparing this paper the authors were supported by the other members of this working group. The final draft was reviewed by members of the Technical Committee on Security and Protection in Information Processing Systems (TC-11) of the International Federation for Information Processing (IFIP). The paper is adopted in May 1994 as a formal policy statement / position paper by IFIP TC-11.

INTRODUCTION

This position paper states the position that IFIP TC-11, as worldwide organisation of professionals, working in the field of information security, takes towards the development, existence and application of Security Evaluation Criteria, further referred to as SEC, in general. It is not focussed on any particular set of criteria, such as the Trusted Computer Security Evaluation Criteria (TCSEC) or the Information Technology Security Evaluation Criteria (ITSEC). IFIP TC-11 wants to focus on the general principles that govern the establishing, maintenance and application of a (any) set of SEC as an international standard by industry and users in the field of information technology. Also IFIP TC-11 wants, through its position paper, to express viewpoints on general requirements that any standard-set of SEC should adhere to from a professional and IT-users point of view and with respect to the ongoing developments in Information Technology.

IFIP TC-11 considers SEC to be of major importance to further and develop general notions about and in-depth views on information security in general. This importance can be derived from the deep and thorough influence the Orange Book has had on current operating systems. IFIP TC-11 expects that SEC will play an important role in a growing understanding of security functionality needs of international commerce and IT-industry.

IFIP TC-11 taking up position towards the development and existence of SEC doesn't mean that its viewpoints are altogether set firm and unshakable. Rather the intention is to draw lines in ongoing discussions and to advise governmental and standardization bodies. The discussion however, is not at all to be finished, let alone be obstructed.

This position paper is divided in four separate sections:

1. What objectives should be pursued with SEC.
2. What should be the scope of SEC.
3. What should be minimal requirements for a set of SEC, what contents must be expected, both in the criteria themselves and in the evaluation process.
4. What are the preconditions that are necessary for SEC to be effective and to be accepted.

1 OBJECTIVES

SEC in general are not only intended for application in the evaluation and certification of IT-products and -systems on (the level of) security functionality thereof. They must at the same time be aimed at contributing to an integral, consistent, analytical, pragmatic and cost-effective approach to IT-security within the user environment. The current focus of SEC is on IT-products that can be evaluated on (aspects of) their security functionality in a general or specific context. As such the IT-industry is a major stakeholder in providing trusted IT-products through the application of SEC. It must however not be forgotten that the general issue at hand is: the security of information and information processing, that supports the users main business-processes.

SEC must become an integral part of a wider set of standards. SEC can only be of limited importance in the whole of security matters in a specific user environment. They cannot replace a complete and tailored set of security requirements in the specific user environment. IT security development should be supported by a basic set of standards that can give guidance for the security related activities that begin with the specification of security requirements and end with installed and accepted IT systems. The structure for this basic set of standards could be as follows:

- Corporate Security Policy, which could address:
 - overview of the organisation and risk areas;
 - principles to govern security;
 - objectives for Baseline Controls;
 - related documents to be produced.
- Technical Security Policy, which could address:
 - IT product security requirements;
 - IT system management.
- Implementation Guides and Tools, which could address:
 - implementation guides for each product;
 - tools to verify product compliance with the Baseline Controls.

SEC must provide real security. Information technology products or systems that have too little security functionality and/or assurance, must fail evaluation against any level. The lowest security evaluation level must be more than just proper documentation/administration and other "good practices" procedures. It must be clear that passing such evaluation means very little in terms of real security.

2 SCOPE OF SEC

SEC must support the whole life-cycle of IT-products and systems to be evaluated, including the design and development process. Until now evaluations have taken place mainly for existing products. However, it would be more appropriate for SEC to give guidance to the design and development process by suggesting codes of "good design" and "good development practice" that would increase the chance of building a secure product. Whenever developers follow this guidance, evaluations of the resulting products will be easier, and hence cheaper. This in turn would decrease the rather prohibitive cost-barrier currently associated with evaluation at low assurance levels.

SEC must support the evolutionary nature of products and systems. IT Products and systems are not fixed but are subject to change and evolution. SEC should not ignore this "fact of life" but address the need to constantly re-verify the system in its subsequent evolutionary stages against the security target. One-time evaluations are inadequate.

SEC must provide for a variation of administration and protection approaches across multiple computing platforms and organizational structures. The key words we want to stress here are "administration" and "organizational". Current SEC fall short on their applicability to real-life environments. An example where current SEC have insufficient applicability is an organization with a strong ("mandatory") segregation of duty.

3 CRITERIA REQUIREMENTS

Criteria, components, protection profiles, and security target

SEC should separate criteria, protection profiles, components, and the security target. A definition of these notions is given hereafter. The separation between criteria, components, and profiles is consistent with the work done in the Federal Criteria (FC). The security target derives more from ITSEC. All four notions deserve specific attention - i.e. while it is possible (and has been done) to use all four terms for the same things, it leads to a more fruitful discussion if SEC standards would limit the definition of each of the terms to a specific meaning.

SEC should describe atomic criteria, i.e. a scale in one criterion must really describe an increasing requirement in only one dimension. This means to say that there is a yardstick (the level of the requirement) for each single evaluation criterion. In its most basic form, the scale is binary (i.e. either it does meet the criterion or it does not), but it can contain any number of levels as refinements are needed. Current efforts to formulate criteria sometimes result in non-atomic criteria where existing software is found to exceed a requirement in one sense and to fall short in an other sense. Clearly this means that two (sub-)criteria with independent requirement scales must exist, and hence the specific criterion has not been defined properly.

SEC should allow the specification of a security target, where a security target is a consistent set of requirements per criterion, jointly applicable to a consumer situation. The operative word here is "consumer situation", i.e. the set of requirements must describe a real-life need in e.g. industry or government systems. This may or may not be a common need (see hereafter). It contains/implies a security policy and may imply a specific operating environment. A product vendor can also be regarded as an organization that formulates consumer needs (since generally products try to meet a consumer need).

SEC should provide and allow standardization of protection profiles, where a protection profile is a consistent set of requirements per criterion, jointly applicable to a common consumer situation or agreed upon by a number of product vendors. The operative words here are "common" and "consumer situation", i.e. the set of requirements must describe a real-life need in e.g. a number of industry or government systems. While a security target may be defined as a hypothetical solution for a need for purposes of research, or as the

need for one unique project, to become a standard in itself (i.e. a protection profile) it must have a wider scope of applicability. In addition, vendors should be able to agree upon a common security functionality for a specific type of component (e.g. network routers), and have the interface specifications standardized.

SEC can partly be organized into "components", where a component is a consistent set of criteria with possibly interdependent requirement levels (i.e. a consistent combination of scores on a set of separate criteria). This is meant to be able to break down a protection profile into a number of large chunks. The essential difference in definition with protection profile is

- a. That the component by itself need not be applicable to any situation - it is a subset;
- b. That the component itself can have a scale, where each level encompasses a set of levels of the criteria contained in the component.

Thus a component can look remarkably like a non-atomic requirement, for those who want to have it. In addition it is not necessarily policy-neutral, whereas criteria are as policy-neutral as one can get without overlooking that a criterion can sometimes be used only with certain policies (and hence is not policy-neutral).

For a component to become (part of) a standard, it must as a whole be part of multiple protection profiles that are (to become) a standard. This expresses the opinion that a standardized component only has a right to exist if it is isolated from existing protection profiles, not the other way around (i.e. that a protection profile should consist of standardized components). Also, we feel that existence in one standardized protection profile is not enough to consider it for a standard component - this would only invite a proliferation of components and the "fast" construction of new protection profiles from these components, without due attention to the actual consumer need.

Trusted Computing Bases and their interactions

The Trusted Computing Base (TCB) concept is valuable and should be retained. Likewise the subdivision of the TCB into security enforcing and security relevant parts is valid. When evaluating computer systems, it is desirable to be able to divide the system into parts and to minimize the number of parts to be analyzed. We would like to define the TCB as the combination of parts that can influence adherence to the security target. In badly designed or leaky systems, this will be the complete system, in well-designed systems this should be a relatively small part.

SEC should provide a method to combine evaluation results of building blocks under the condition that they communicate through well-defined, evaluated interfaces (e.g. Security Application Programming Interface (API), protocols). Current SEC grossly fail to address the most common concern in systems today, i.e. building a safe system from multiple products, both running in one physical computer and running on interconnected computers. Without being able to combine evaluated products in a manner preserving the evaluation results, evaluation results are probably not applicable to any real-life system.

SEC should cover the interaction of independent TCBs both in peer-to-peer relations and in hierarchical relations (super/subset). For evaluated systems to work together, security relevant information must be exchanged, and security enforcing decisions are made based on the exchanged information. Criteria must exist to measure and evaluate the safeguards

for this process. This exchange takes place when two peer systems exchange information, but also when a part of the system subdivides an object of the supervising system into smaller objects (i.e. a database management system (DBMS) can provide a refinement over an operating system (OS) by providing record/column level access to information in what the OS sees as a single object). The access control decisions are made "locally" based on information (e.g. identity) passed from other parts of the system.

Taxonomy for Targets of Evaluation

As regards the current discussion on providing criteria for products versus criteria for systems we feel that the situation can be clarified by stating that all of the following levels of Targets of Evaluation (TOE, defined within the ITSEC document as: an IT system or product which is subjected to security evaluation) should be covered by SEC:

1. Implementation of a set of "integrated products" into a specific organization.
2. An "integrated product" consisting of a set of products configured to operate together.
3. A "product", usually an off-the-shelf, single-vendor hardware or software system.
4. A "component" as a logically coherent set of measures to meet a subset of security requirements.

Each level potentially has a 1:n relation to the level below it, i.e. each higher level TOE can contain multiple items from a lower level of TOE. Levels 1-2-3 clarify the current confusion on products versus systems.

1. At the highest level, we have a specific environment (one of a kind), where a term like "accreditation" can be used to indicate the process of approving a product for use in that specific environment (probably under certain conditions). To analyze security at this level, organizational measures can be used to address shortcomings of the integrated products. This level is in fact the TOE that is most often analyzed around the world.
2. This is the level where the integration of products (possibly of different vendors) is analyzed. Here, strict adherence to well-defined interfaces (e.g. APIs) is required to demonstrate the functionality of the integrated product. Also, the configurable options of each product have to be set in a manner that ensures interoperability. Here we can e.g. analyze a compound system (the actual configuration used in "real-life"), based on a combination of hardware, OS, DBMS, network, security software, etc.
3. This is the level focused on by the SEC today, where a single product from one vendor, usable on a number of consumer systems, is analyzed. This might for instance be a piece of hardware, an OS, a DBMS, or a networking system. Even at this level, strong assumptions are needed about the operating environment (e.g. an OS is evaluated under the assumption that the hardware behaves in a certain, documented, manner).
4. This level is the breakdown of security functionality into common components. A component can be identified as a set of requirements in a specific area that is common to some (many?) products. E.g. "identification & authentication" may be a component of many products, but it is not required for all products. Other products might have a component "Anonymity and non-traceability". The component is the place where a set of criteria normally used to evaluate against, can themselves become a TOE, to be analyzed for consistency, etc.

Assurance and Functionality criteria

Functionality concerns should be separated from assurance concerns. The possibility to rate functionality and assurance separately is a major enhancement of recent SEC over early SEC work, because it increases the orthogonality of the requirements.

Functionality criteria should be logically and explicitly tied in with aspects like continuity, integrity, accessibility, robustness, auditability, etc. It must be inherently clear to what extent the use of a "certified" IT product mitigates the risks that the user intends to deal with. By using separate components for each security or quality aspect, this becomes more clear than when using an unordered set of some hundred evaluation criteria.

Assurance concerns should at least be separated into "development assurance" and "evaluation assurance". The clear separation of criteria according to the kind of assurance they purport to measure helps in designing balanced sets of criteria. Recent criteria like the Canadian Trusted Computer Product Evaluation Criteria (CTCPEC) already try to address this.

The relationship between tools for risk-analysis and tools supporting security evaluation criteria must be strengthened. Risk analysis is normally done in an early stage in product development, preferably while designing the specifications of a product. It results in functional security requirements and technical specifications. These may later form the basis for evaluation. The presence of the original risk analysis will generally increase the level of assurance. Also, it provides a link with other means to security than purely technical measures. This link is of considerable importance in evaluating a product in its operational environment.

SEC should generally require vendors to supply documentation to the users, that shows how the reliability of security features is being ensured. A vendor should explain to the user why he should trust the product. A written testimony on the reliability of security enforcing features increases the development assurance.

4 PRECONDITIONS

In this section, preconditions are listed that are necessary for SEC to be effective, efficient and accepted by suppliers as well as consumers.

SEC must be of a global level. To achieve this, SEC must be established as one international standard and mutual recognition has to be achieved. In order to become accepted worldwide by both the producers and users communities, it is highly essential that no more than one set of criteria is used. Therefore, SEC should preferably be established as an ISO standard. In accordance with this one standard, it is equally essential that the evaluations and certifications performed in different countries, are recognized by all the other countries, without additional requirements. This mutual recognition of the results of evaluation and certification processes is necessary for these processes to become cost effective. If they are not cost effective, it will be too expensive for both producers and users to have products/systems evaluated.

The use of standards and profiles should be supported. SEC should indicate how developers can effectively make use of existing standards to offer security in their products. The

use of standards will offer a more predictable level of security (in general: a higher level) and be of great benefit in the evaluation of products. Security standards/profiles and non-security standards/profiles should be distinguished. Standards should be added to a list, stating the required security functionality and interfaces and an 'evaluation-method' or 'test-suite'.

Product security profiles should be listed. To increase the useability of SEC for manufacturers / suppliers of products, it must be made possible to express the security functionality and interfaces of products in terms of the SEC, and add these product-profiles to a list, for example as an appendix to the international standard.

Functionality profiles should be listed. To increase the useability of SEC for customers of security products and systems, it must be possible to define the required security functionality in the customer's situation (possibly branche-oriented) in terms of SEC and add these security functionality profiles to a list, for example as an appendix to the international standard.

SEC must provide enough flexibility to apply security measures to meet different security policies within the international business and governmental environment. SEC must be suitable both for military, governmental and commercial environments. These requirements must fit in one general framework. However, SEC must not contradict with legitimate and generally recognized security interests and principles within national intelligence/security authorities. On the other hand, SEC must not impose or be used as international trade barriers.

Awareness programmes should be started, concerning the existence, contents and application of SEC. Management of user-organisations, responsible for a safe and secure business-process and for application of IT to that end, must be made aware of the existence and scope of a specific set of SEC and of their applicability to IT-products and systems. Responsibility for adequate publication, and other awareness-efforts to that end, do not only rest on governmental and standard-setting bodies but also on the commercial and professional IT-security establishment.

SEC must keep up with developments in information technology. SEC must follow in a rapid pace and respond quickly to the evolution of information and communication technologies; the international decision processes to establish new and enhanced standard-criteria must accordingly be quick; SEC must therefore provide adaptability in itself to incorporate new technologies on a selective or global basis.

ABBREVIATIONS

API	Application Programming Interface
CTCPEC	Canadian Trusted Computer Products Evaluation Criteria
DBMS	Database Management System
FC	Federal Criteria
IT	Information Technology
ITSEC	Information Technology Security Evaluation Criteria
OS	Operating System
SEC	Security Evaluation Criteria
TCB	Trusted Computing Base
TCSEC	Trusted Computer Security Evaluation Criteria
TOE	Target Of Evaluation

REFERENCES

- Canadian Trusted Computer Product Evaluation Criteria (CTCPEC), version 3.0, January 1993, Canadian System Security Centre / Communications Security Establishment / Government of Canada, Canada
- FC Comment applicable to draft V1.0 of Volumes FC1 and FC2, 30 March 1993, Dutch Computer Society (NGI) Special Interest Group on Information Security (SIGIS), Amsterdam, The Netherlands
- Federal Criteria for Information Technology Security (FC), version 1.0, December 1992, National Institute of Standards and Technology (NIST) / National Security Agency (NSA), Gaithersburg, USA
- Information Technology Security Evaluation Criteria (ITSEC), Provisional Harmonised Criteria, version 1.2, 28 June 1991, Commission of the European Communities, Brussels, Belgium, ISBN 92-826-3004-8
- Information Technology Security Evaluation Manual (ITSEM), version 0.2, 2 April 1992, Commission of the European Communities, Brussels, Belgium
- ITSEM Comment applicable to draft V0.2, 29 June 1992, Dutch Computer Society (NGI) Special Interest Groups Information Security, EDP-Audit and Databaseclub, Amsterdam, The Netherlands

